Chatbot público de SIHUL para la página de la Universidad

Informe de diseño y plan de trabajo · para revisión antes de construir · octubre de 2026

> **En una frase:** cada seccional recibe **un enlace** que abre una página limpia con **solo el chatbot** (sin menú, sin inicio de sesión, sin captcha visible), con un botón claro para volver a la página de la Universidad. Por detrás, el servidor exige una sesión firmada y aplica límites, para que nadie pueda gastar los tokens de IA llamando directamente al servicio.

1. Por qué hay que hacerlo (el problema de hoy)

- El chat público actual muestra un reCAPTCHA **solo en la pantalla**. El servicio que contesta las preguntas (`/api/chatbot/public/pregunta/`) **no verifica nada** y no tiene límite de uso: quien conozca la dirección puede llamarla con un programa y gastar la IA sin pasar por la página.
- No hay límite por persona o por IP, ni tope de longitud de la pregunta, ni tope diario de gasto.
- Si algo falla, el servicio devuelve el texto del error interno al visitante.
- Publicar un enlace en la página principal de la Universidad multiplica la exposición: hay que cerrar esto **antes** de entregarlo.

2. Cómo está construida la página de la Universidad

Revisé `https://www.unilibre.edu.co/`. Lo que sé y lo que no:

Hallazgo	Consecuencia para el chatbot
Es un sitio **WordPress** (rutas `/wp-content/`), probablemente con el constructor Bricks.	Se puede poner un enlace o botón sin programar. Un iframe o un script exige permiso de quien administra el WordPress.
No hay un dominio por seccional. Todas son rutas del mismo dominio: `/bogota`, `/barranquilla`, `/cali`, `/pereira`, `/cucuta`, `/cartagena`, `/socorro`; Virtual en `/programas-virtuales/`.	El enlace de retorno de cada seccional es una URL conocida y estable. Para incrustar solo hay que autorizar un dominio principal.
Hay subdominios propios: `siul.unilibre.edu.co` (sistema académico), `inv-centenario`, `revistas`, `libros`, `comunicaciones`.	Se autoriza `*.unilibre.edu.co` como origen permitido, no solo `www`.
Encabezado con **selector de perfil** (Aspirante, Estudiante, Profesor…), **selector de seccional**, menú: Servicios, Biblioteca, etc.	El enlace del chatbot encaja en «Servicios» o «Biblioteca» de cada seccional, o como botón en la página de la seccional.
Ya existe un enlace «Chatea con nosotros» que apunta a un servicio externo (`chat.invmaver.com`).	Hay que acordar con la Universidad si el nuestro lo reemplaza o convive con él, para no tener dos chats.
No pude comprobar si sus enlaces externos abren en la misma pestaña o en una nueva, ni qué política de seguridad (CSP) tiene su WordPress.	Por eso el diseño funciona en cualquiera de los dos casos, y las opciones de incrustación se confirman con quien administra el sitio.

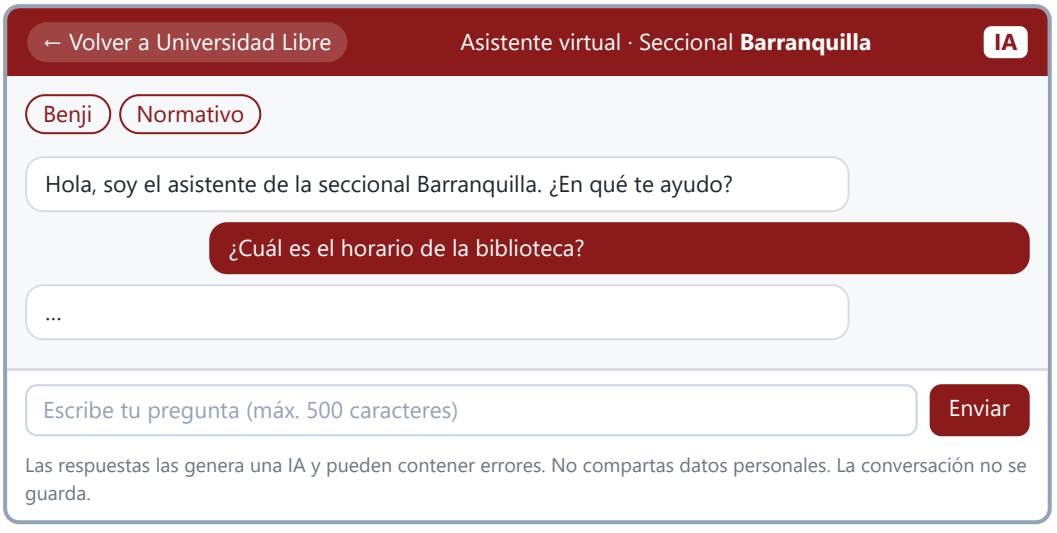
3. Tres formas de mostrarlo

	A. Enlace a página limpia (recomendada)	B. Incrustado en la página (iframe)	C. Burbuja flotante «Chatea con nosotros»

Cómo se ve	Un enlace o botón en la página de la seccional abre nuestra página: solo el chatbot, con una barra superior mínima.	El chatbot aparece **dentro** de una página de WordPress, entre el resto del contenido.	Un botón circular en la esquina de todas las páginas; al pulsarlo se abre un panel de chat.
Cómo se sale	Botón «← **Volver a Universidad Libre**», el botón Atrás del navegador, o cerrar la pestaña.	La persona sigue en la página de la Universidad: sale con su menú normal. No hay «salir» propio.	Cerrar con la **X** o con la tecla **Esc**; la página de detrás nunca se pierde.
Qué pide a la Universidad	**Nada técnico**: pegar un enlace.	Una página con bloque HTML personalizado, y que su WordPress permita incrustar nuestro dominio.	Pegar un fragmento de código en todo el sitio (tema o plugin) y mantenerlo.
Riesgo / fallo posible	Mínimo. Funciona aunque cambien su sitio.	Si su política de seguridad bloquea marcos, no se verá nada. Alturas y barras de desplazamiento dobles en celular.	Dependiente del código pegado; puede chocar con el chat externo actual.
Seguridad	Sin cambios especiales.	Se autoriza solo a `*.unilibre.edu.co` a incrustarlo.	Igual que B.
Esfuerzo nuestro	Bajo	Medio	Medio-alto

> **Recomendación:** entregar la **opción A ya**: un enlace por seccional, que es lo que pidieron (una dirección a la que redirigir). La página se construye de forma que **B y C quedan posibles después** sin rehacer nada (las mismas rutas funcionan como marco). Si la Universidad prefiere incrustarlo, se activa con la configuración de orígenes permitidos.

4. Cómo se ve y cómo se sale



- **Sin menú lateral, sin inicio de sesión, sin captcha visible:** la persona abre el enlace y escribe.
- **La seccional viene fija en el enlace** (por ejemplo `…/asistente/barranquilla`). No hay selector de seccional ni de datos: quien llega desde Barranquilla ve solo lo de Barranquilla.
- **Salir:** el botón «← Volver a Universidad Libre» lleva a la página de esa seccional (`www.unilibre.edu.co/barranquilla`). La dirección de retorno la fijamos nosotros por seccional, **no viaja en el enlace**, para que nadie pueda usar nuestra página para redirigir a sitios maliciosos.
- El botón Atrás del navegador funciona normal: no atrapamos el historial.
- **Celular:** pantalla completa, teclado cómodo, la barra de retorno siempre visible.
- **Reiniciar conversación:** un botón para empezar de nuevo y borrar lo mostrado.

5. Cómo se protege (sin captcha para la persona)

Capa	Qué hace	Qué evita
1. Desafío invisible	Al abrir la página, el navegador resuelve en segundo plano un pequeño cálculo (prueba de trabajo, 1 a 3 segundos). El servidor lo verifica y entrega un **token firmado** de 30 minutos, ligado a la seccional.	Que un programa llame directo al servicio: sin token válido, no se contesta. Cuesta tiempo de cálculo a quien lo automatiza a gran escala.
2. Límites por sesión y por IP	Máximo de preguntas por sesión (por ejemplo 20) y por IP (por minuto y por día).	Que una sola persona o programa gaste demasiado.
3. Tope diario global	Si se supera el presupuesto de preguntas del día, el chat responde «servicio temporalmente no disponible».	Que un ataque distribuido vacíe la cuenta de IA.
4. Validación de entrada	Pregunta de 1 a 500 caracteres, identificador de conversación validado, errores genéricos (nunca el texto interno).	Mensajes enormes, datos extraños, fuga de información.
5. Orígenes autorizados	Solo `*.unilibre.edu.co` y nuestro dominio pueden incrustar la página (cabecera `frame-ancestors`) y llamar al servicio desde un navegador.	Que otros sitios usen nuestro chatbot como propio.
6. Tope de gasto en OpenAI	Proyecto y llave **aparte** para el chat público, con límite mensual duro y alertas por correo (se configura en el panel de OpenAI; la llave la pones tú en el `.env`, yo no la leo).	Es la red de seguridad final: aunque todo lo demás fallara, el daño máximo es ese tope.
7. Vigilancia	Contadores de preguntas por hora y seccional (sin guardar el contenido) y alerta si se disparan.	Enterarse a tiempo de un abuso.

Flujo en palabras: 1) la persona abre el enlace → 2) la página pide un desafío y lo resuelve sola → 3) el servidor lo verifica y entrega el token → 4) cada pregunta lleva el token → 5) el servidor comprueba token, límites y tope diario → 6) recién entonces consulta a la IA y responde.

> **Lo que NO garantiza:** una persona real puede preguntar hasta el límite, y un atacante con muchos recursos puede intentar sortear la prueba de trabajo. Por eso existen los topes (capas 2, 3 y 6): el diseño no busca que sea imposible abusar, sino que abusar **cueste mucho y tenga un techo bajo**.

6. Seguridad también para el acceso público de nuestro login

El chat dentro de `/public/asistente-virtual` (el acceso público que sale desde el login) usa **el mismo servicio**. Al protegerlo con el token, queda cubierto también ese camino, sin cambiar lo que ve la persona: la página pedirá el token por detrás, igual que la nueva. El reCAPTCHA actual del acceso público se mantiene para las otras pantallas públicas (préstamos, consulta de horarios).

7. Cosas del servidor que condicionan el diseño

Hallazgo	Qué haremos
El nginx del frontend pone `X-Frame-Options: SAMEORIGIN` en **todas** las rutas. Eso impediría que la Universidad lo incruste.	Ruta específica del asistente con `frame-ancestors` para `*.unilibre.edu.co`. El resto del sitio sigue sin poder incrustarse.
El HTTPS lo termina un equipo de la Universidad. La IP que ve nuestro servidor puede ser la de ese equipo y no la de cada visitante.	Los límites por IP serán configurables y generosos; los límites fuertes van por sesión y tope diario. **Hay que confirmar con la Universidad que ese equipo envía la IP real en `X-Forwarded-For`.**
Hay Redis en producción.	Se usa para los contadores (compartidos entre todos los procesos del servidor).

La conversación pública ya no se guarda.	Se mantiene; se añade el aviso de uso de IA en pantalla.

8. Plan de trabajo y entrega

Paso	Qué	Dónde
1	Servicio: desafío, sesión firmada, límites, tope diario, validación, errores genéricos, pruebas automáticas.	Backend
2	Página limpia `/asistente/<seccional>` con barra de retorno, reinicio y aviso; el acceso público actual pasa a usar el token.	Frontend
3	Cabecera `frame-ancestors` y tope de tamaño; configuración de orígenes por variable de entorno.	nginx / despliegue
4	Pruebas en el entorno de pruebas, incluido un **intento de abuso** (programa que llama directo) que debe ser rechazado, y pruebas en celular.	Pruebas
5	Revisión del PR, despliegue a producción con respaldo, entrega de los enlaces por seccional.	Producción

Los cambios van en un PR a `develop`, se prueban en el entorno de pruebas (`http://10.4.100.146:5273`) y recién entonces pasan a producción.

9. Qué necesito de ti y de la Universidad

- **Dominio final del chatbot** que se entregará (por ejemplo `sihul.unilibre.edu.co`). Hoy es el del sistema.
- **Quién administra el WordPress** y si aceptan A (enlace), B (iframe) o C (burbuja).
- **Si reemplaza o convive con** el «Chatea con nosotros» actual.
- **Qué seccionales** entran primero (Barranquilla, Bogotá, Pereira… y qué chatbots en cada una).
- **Tope diario inicial** de preguntas (propongo 1.500 al día en total y 20 por sesión; se ajusta con datos reales).
- **Proyecto y llave de OpenAI aparte** con límite mensual (lo configuras tú en el panel).
- **Confirmación del equipo de red** de la Universidad: ¿envía la IP del visitante en `X-Forwarded-For`?
- **Textos finales:** nombre del asistente y aviso legal / de uso de datos.

10. Riesgos y mitigación

Riesgo	Mitigación
Abuso masivo para gastar tokens	Capas 1 a 3 y tope de gasto en OpenAI.
La Universidad cambia su sitio y el enlace se rompe	El enlace apunta a una ruta estable nuestra; solo cambia el botón de ellos.
La página de la Universidad bloquea marcos	La opción A (enlace) no depende de eso.
Respuestas incorrectas o fuera de tema	El chatbot solo responde con los documentos cargados por cada seccional y avisa cuando no hay información; aviso visible de uso de IA.
Datos personales escritos por los usuarios	No se guarda la conversación; aviso en pantalla de no compartir datos personales.

11. Decisiones que necesito para empezar

1. ¿Entregamos primero la **opción A** (enlace a página limpia)? *(recomendada)*
2. ¿Anti-bot **propio** (prueba de trabajo, sin terceros) o reCAPTCHA v3 invisible? *(recomendado: propio)*
3. ¿Las seccionales y chatbots de la primera entrega?
4. ¿Aceptas el tope diario inicial propuesto?